OrangeIT

CHECKLIST DE MATURIDADE EM SEGURANÇA

SUA EMPRESA ESTÁ PRONTA PARA UM PENTEST?

Um guia prático para líderes de negócio e equipes de TI avaliarem o nível real de prontidão cibernética da sua organização, antes de contratar qualquer serviço de segurança.

ORANGEIT.COM.BR | CONTATO@ORANGEIT.COM.BR | 2026

SOBRE ESTE GUIA

POR QUE VOCÊ PRECISA SABER SEU NÍVEL DE MATURIDADE ANTES DO PENTEST?

Contratar um pentest sem entender o estado atual da sua segurança é como pedir uma auditoria financeira sem saber se os lançamentos estão em dia. O resultado vai existir — mas você talvez não esteja pronto para o que vai encontrar.

- Este guia foi desenvolvido pela Orange IT para ajudar organizações de qualquer porte e setor a fazerem uma autoavaliação honesta da sua postura de segurança cibernética. Não é necessário ter conhecimento técnico avançado para completar o checklist — ele foi desenhado para ser acessível tanto ao CISO quanto ao CEO.
- Ao final, você terá clareza sobre três coisas:
-
- Em qual nível de maturidade sua empresa se encontra hoje
- Quais são as lacunas que precisam ser endereçadas com maior urgência
- Se sua organização está pronta para extrair valor real de um pentest
-
- A avaliação é composta por 5 categorias e 25 perguntas. Para cada pergunta, atribua uma pontuação de 0 a 2 conforme a sua realidade atual. Some os pontos ao final de cada categoria e consulte a tabela de resultados.
-

COMO USAR ESTE CHECKLIST

GUIA DE PONTUAÇÃO

Para cadaitem do checklist, escolha a opção que melhor descreve a situação atual da sua empresa:

PONTOS	0 — Não temos	1 — Temos parcialmente	2 — Temos e está funcionando

Seja honesto na avaliação. O objetivo não é obter uma pontuação alta — é ter uma visão real do estado atual para tomar decisões melhores. Uma pontuação baixa não é um problema; é uma informação valiosa.

CATEGORIA 1 DE 5

Inventário e Visibilidade de Ativos

Você não pode proteger o que não conhece. Esta categoria avalia se sua organização tem visibilidade clara de todos os ativos digitais — sistemas, dispositivos, aplicações e dados — que fazem parte da sua superfície de ataque.

☐	**Inventário atualizado de ativos** Existe uma lista atualizada de todos os servidores, dispositivos, aplicações e endpoints da organização? O inventário é revisado com frequência mínima trimestral.
☐	**Mapeamento de aplicações críticas** As aplicações críticas de negócio estão identificadas e classificadas por criticidade? Existe clareza sobre quais sistemas, se comprometidos, gerariam maior impacto operacional ou financeiro.
☐	**Controle de shadow IT** Há um processo para identificar e controlar sistemas e aplicações instalados sem aprovação da TI? O uso de ferramentas não homologadas (como armazenamento em nuvem pessoal) é monitorado.
☐	**Visibilidade de ativos em nuvem** Todos os recursos em ambiente cloud (AWS, Azure, GCP) estão catalogados e sob gestão centralizada? Não existem ambientes órfãos ou contas abandonadas sem monitoramento.

☐	**Gestão de terceiros e integrações** Os sistemas de fornecedores, parceiros e integrações externas estão mapeados? Existe avaliação de risco para acessos concedidos a terceiros.

Pontuação desta categoria: ____ / 10

CATEGORIA 2 DE 5

Gestão de Identidades e Acessos

A maioria dos ataques modernos passa por credenciais comprometidas ou privilégios excessivos. Esta categoria avalia a maturidade dos controles de identidade e acesso da sua organização.

☐	**Política de senhas e MFA** Existe uma política formal de senhas com requisitos mínimos de complexidade? A autenticação multifator (MFA) está habilitada para todos os sistemas críticos e para acesso remoto.
☐	**Princípio do menor privilégio** Os usuários possuem apenas os acessos necessários para exercer suas funções? Existem revisões periódicas de privilégios e um processo formal para revogação de acessos ao desligamento.
☐	**Controle de contas privilegiadas** As contas de administrador estão segregadas das contas de uso cotidiano? Existe monitoramento de ações realizadas por contas com privilégio elevado (PAM).
☐	**Gestão de acessos de terceiros** Os acessos concedidos a fornecedores, prestadores e parceiros são temporários e revisados? Existe controle sobre quais sistemas externos podem ser acessados por terceiros.
☐	**Single Sign-On e federação de identidade** A organização utiliza SSO para centralizar autenticação? Existe integração com diretórios corporativos (Active Directory, Azure AD) com políticas de acesso condicional.

Pontuação desta categoria: ____ / 10

CATEGORIA 3 DE 5

Detecção e Resposta a Incidentes

Saber que você foi atacado — e conseguir responder rapidamente — é tão importante quanto tentar prevenir ataques. Esta categoria avalia se sua organização tem capacidade de detectar, responder e se recuperar de incidentes de segurança.

☐	**Monitoramento e alertas de segurança** Existe uma solução de monitoramento contínuo (SIEM, EDR ou equivalente) gerando alertas em tempo real? Os logs de sistemas críticos são coletados e analisados de forma centralizada.
☐	**Plano de resposta a incidentes documentado** Existe um plano formal e documentado de resposta a incidentes? O plano define papéis, responsabilidades, fluxos de comunicação e procedimentos de contenção para os principais cenários de ataque.
☐	**Testes e simulações de resposta** O plano de resposta a incidentes foi testado nos últimos 12 meses? Exercícios de tabletop ou simulações de ataque foram realizados com as partes interessadas.
☐	**Backup e recuperação validados** Os backups críticos são realizados regularmente e armazenados em ambiente isolado (offsite ou offline)? A restauração foi testada nos últimos 6 meses e o RTO/RPO está definido.
☐	**Comunicação de crise e notificação regulatória** Existe um protocolo de comunicação para notificar clientes, parceiros e autoridades (ANPD) em caso de incidente? Os prazos da LGPD para notificação de vazamentos estão mapeados e há responsável designado.

Pontuação desta categoria: _____ / 10

CATEGORIA 4 DE 5

Gestão de Vulnerabilidades

Vulnerabilidades não remediadas são a porta de entrada mais comum em ataques bem-sucedidos. Esta categoria avalia se sua organização tem um processo estruturado para identificar, priorizar e corrigir vulnerabilidades antes que sejam exploradas.

☐	**Processo de gestão de patches** Existe um processo formal e cadenciado para aplicação de patches de segurança? Os sistemas críticos recebem atualizações em até 72 horas após disponibilização de patch para vulnerabilidades críticas.
☐	**Varreduras de vulnerabilidade periódicas** Scans automatizados de vulnerabilidade são realizados com periodicidade mínima mensal? Os resultados são triados, priorizados por criticidade e têm responsável pela remediação.
☐	**Gestão de vulnerabilidades em aplicações** O ciclo de desenvolvimento de software inclui análise de segurança (SAST/DAST)? Vulnerabilidades identificadas em aplicações próprias têm SLA definido para correção.
☐	**Controle de configuração segura (Hardening)** Existe uma baseline de configuração segura para servidores, estações de trabalho e dispositivos de rede? O desvio de configuração é detectado e corrigido de forma sistemática.
☐	**Pentest ou Red Team nos últimos 12 meses** A organização realizou um teste de penetração conduzido por equipe externa qualificada no último ano? Os achados foram remediados e validados com reteste.

Pontuação desta categoria: _____ / 10

CATEGORIA 5 DE 5

Cultura, Governança e Conformidade

Segurança cibernética é uma decisão de negócio, não apenas uma questão técnica. Esta categoria avalia se a sua organização tem a estrutura de governança, os processos e a cultura necessários para sustentar a segurança no longo prazo.

☐	**Política de segurança da informação formalizada** Existe uma Política de Segurança da Informação documentada, aprovada pela liderança e comunicada a todos os colaboradores? A política é revisada anualmente ou quando há mudanças relevantes no negócio.
☐	**Treinamentos regulares de conscientização** Os colaboradores recebem treinamentos de segurança com frequência mínima anual? Simulações de phishing são realizadas para medir e reduzir a suscetibilidade da equipe.
☐	**Responsável formal por segurança (CISO ou equivalente)** Existe uma pessoa ou área formalmente responsável pela segurança da informação? A liderança de segurança tem acesso e reporte direto à alta administração.

☐	**Conformidade com LGPD e frameworks de segurança** A organização mapeou o tratamento de dados pessoais e implementou os controles exigidos pela LGPD? Existe aderência a algum framework de segurança (ISO 27001, NIST, CIS Controls).
☐	**Segurança como critério em decisões de negócio** O risco cibernético é considerado formalmente em decisões estratégicas, fusões, aquisições e contratações de fornecedores? A segurança tem representação nas discussões de board ou comitê executivo.

Pontuação desta categoria: _____ / 10

RESULTADOS

Tabela de pontuação final

Some os pontos de cada categoria e registre abaixo. A pontuação total máxima é 50 pontos.

	CATEGORIA	PONTUAÇÃO	MÁX.
1	Inventário e Visibilidade de Ativos	-	10
2	Gestão de Identidades e Acessos	-	10
3	Detecção e Resposta a Incidentes	-	10
4	Gestão de Vulnerabilidades	-	10
5	Cultura, Governança e Conformidade	-	10
	PONTUAÇÃO TOTAL	**-**	**50**

O que a sua pontuação significa?

0 – 15	**Nível Inicial — Alta Exposição ao Risco** Sua organização opera com controles de segurança muito limitados. Um pentest neste momento provavelmente revelará dezenas de vulnerabilidades críticas sem que haja capacidade de remediar todas. A prioridade imediata é implementar controles básicos de segurança antes de avançar para testes de penetração. A Orange IT pode ajudar a criar um roadmap de maturidade para chegar ao próximo nível.
16 – 25	**Nível em Desenvolvimento — Fundações Presentes, Lacunas Relevantes** Existem controles básicos implementados, mas com lacunas significativas que aumentam o risco operacional. Um pentest será útil para identificar os pontos críticos, mas a remediação exigirá priorização cuidadosa. Recomenda-se um pentest focado nas áreas de maior criticidade enquanto os fundamentos são consolidados
26 – 35	**Nível Estruturado — Pronto para um Pentest Efetivo** Sua organização tem uma postura de segurança estruturada e está bem posicionada para extrair valor real de um pentest. Os controles existentes permitem contextualizar os achados e executar a remediação de forma organizada. Este é o momento ideal para realizar um pentest completo e avançar para um modelo de segurança proativo.
36 – 50	**Nível Avançado — Maturidade para Red Team e Testes Contínuos** Parabéns — sua organização tem uma postura de segurança madura. Pentest convencional pode não ser suficiente para desafiar sua defesa. É o momento de considerar exercícios de Red Team, simulações de APT e programas de teste contínuo (PTaaS). A Orange IT possui a expertise necessária para atuar neste nível.

PRÓXIMOS PASSOS

O que fazer com os resultados

Independentemente da sua pontuação, o mais importante é o que você faz com a informação. Aqui estão as ações recomendadas por nível de maturidade:

1. Compartilhe os resultados com a liderança

Segurança cibernética é uma decisão de negócio. Leve os resultados desta avaliação ao CEO, CFO ou board com uma narrativa de risco em linguagem de negócio — não técnica. Mostre o impacto financeiro e reputacional de cada lacuna identificada

2. Priorize as categorias com menor pontuação

Identifique as 2 ou 3 categorias com maior déficit e crie um plano de ação com responsável e prazo. Não tente resolver tudo ao mesmo tempo — pequenas melhorias consistentes geram mais resultado do que iniciativas amplas sem execução.

3. Defina o escopo do pentest com base nos gaps identificados

Se você decidir avançar com um pentest, use os resultados deste checklist para definir o escopo com precisão. Um pentest bem delimitado — focado nas áreas de maior risco — gera resultados mais acionáveis do que um teste genérico.

4. Estabeleça uma cadência de reavaliação

A maturidade de segurança não é um destino — é um processo contínuo. Refaça esta avaliação a cada 6 meses ou após mudanças relevantes na infraestrutura, no time ou no modelo de negócio. Compare os resultados ao longo do tempo para medir evolução.

5. Converse com a Orange IT

Se você quiser transformar estes resultados em um plano de ação concreto, estamos disponíveis para uma sessão de diagnóstico gratuita. Em 30 minutos, analisamos sua pontuação, identificamos as prioridades e apresentamos as opções disponíveis para o seu contexto.

OrangeIT

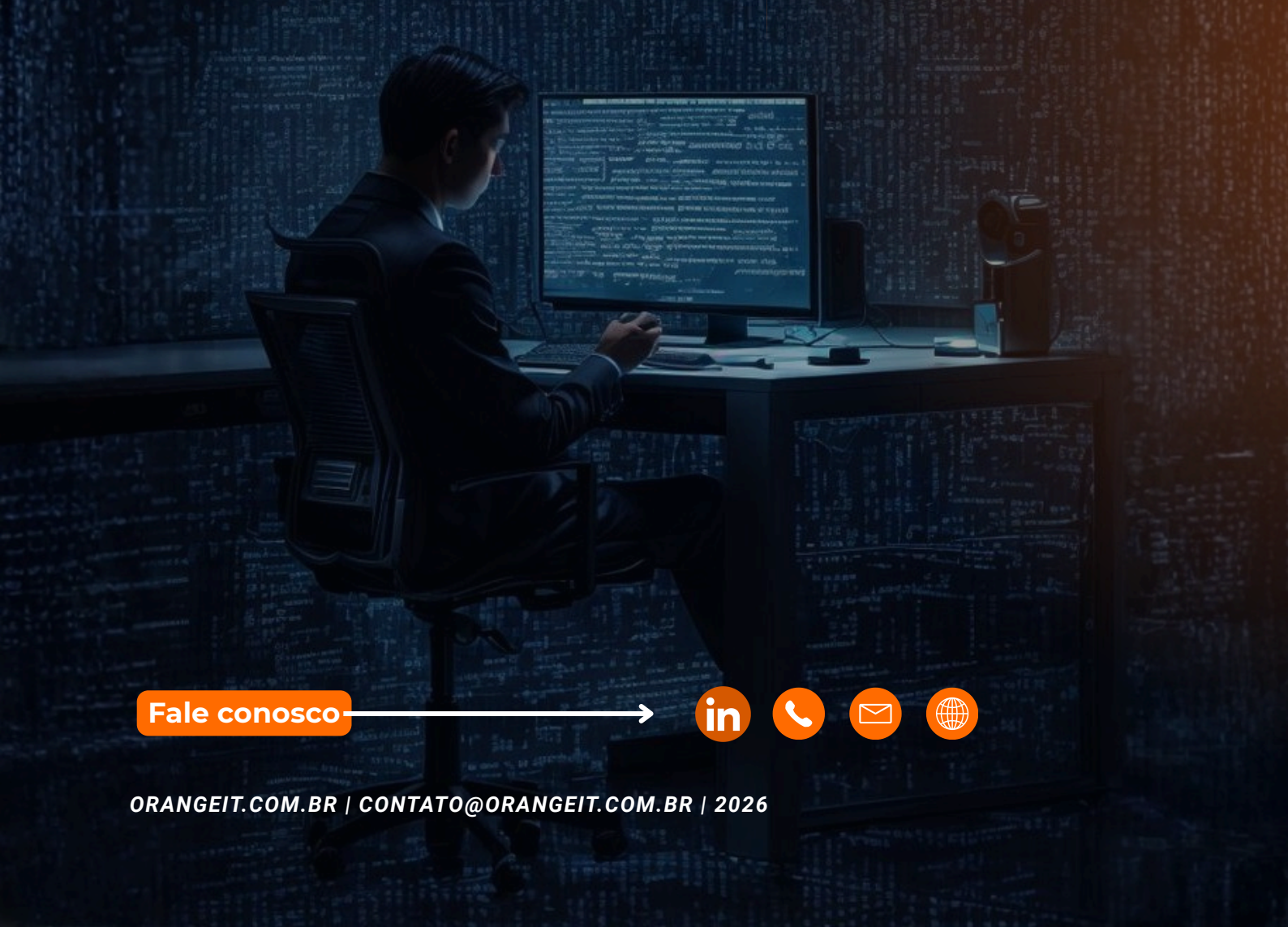
Inteligência ofensiva em neutralização de ameaça digital.

Agende uma sessão de diagnóstico gratuita e descubra o próximo passo certo para a sua organização.

OrangeIT

CHECKLIST DE MATURIDADE EM SEGURANÇA

SUA EMPRESA ESTÁ PRONTA PARA UM PENTEST?



Fale conosco

ORANGEIT.COM.BR | CONTATO@ORANGEIT.COM.BR | 2026